

Cybersecurity Fundamentals

A practical study reference with foundational concepts, examples, and common review questions.

1. Principles and Risk

The CIA triad is confidentiality, integrity, and availability. A threat could cause harm; a vulnerability is a weakness; risk combines likelihood and impact; a control reduces risk. Threat modeling identifies assets, trust boundaries, attack paths, and mitigations.

Defense in depth uses complementary controls. Least privilege limits access; secure defaults reduce exposure; separation of duties distributes sensitive authority. Security is an ongoing process, not a product guarantee.

2. Identity and Data

Authentication verifies identity; authorization grants actions. MFA combines independent factors. Encrypt data in transit with correctly configured TLS and protect stored data and keys. Hashing is one-way; password storage requires a slow salted scheme such as Argon2, scrypt, or bcrypt, not a fast general-purpose hash.

Segment networks, patch exposed services, disable unused accounts and ports, protect secrets, and log security events without recording passwords or tokens. Replication is not a substitute for an independent tested backup.

3. Application and Incident Security

Use parameterized queries to prevent SQL injection. Context-aware output encoding and safe templating reduce XSS. Protect state-changing requests against CSRF where applicable. Validate server-side input, enforce authorization on every protected operation, and keep dependencies current.

Incident response commonly includes preparation, detection, containment, eradication, recovery, and lessons learned. Preserve evidence, document actions, follow escalation procedures, and communicate through approved channels. Test only systems you own or have explicit permission to assess.

4. Common Questions and Habits

Encryption is reversible with the appropriate key; hashing is designed to be one-way. Phishing deceives people into revealing information or taking unsafe actions. A zero-day describes a vulnerability unknown to or not yet fixed by a responsible vendor, depending on context.

Use unique passwords with a password manager, enable MFA, verify unexpected requests independently, update software, and report suspected incidents. Security testing without permission is not acceptable.